

1. Generative AI Usage Policy

Employees are permitted to use AKP self-hosted internal LLM service for daily work tasks: draft documents, summarize internal meeting notes, assist code review.

STRICTLY PROHIBITED: Input PII, customer personal records, confidential architecture, trade-secret material into public third-party AI services (ChatGPT, public cloud LLM APIs).

允许员工使用公司内部部署大模型完成文档起草、会议纪要总结、辅助代码评审。严禁将PII、客户记录、机密架构、商业秘密输入公有第三方AI。

1.1 PII Handling Rules

PII definition: phone numbers, personal email addresses, national ID numbers, residential addresses, customer payment records, user-identifiable log entries.

Any PII appearing inside user input or system outputs must be redacted before logging or long-term storage.

Log storage systems must never persist raw unredacted PII values.

If user query contains PII, the RAG QA service shall reject processing that request.

PII包含手机号、个人邮箱、身份证、住址、客户支付记录。任何用户输入、输出中的PII在日志持久化前必须脱敏。如果用户查询本身携带PII，RAG-QA服务应当拒绝处理该请求。

2. Knowledge-Base Agent Compliance Rules

The internal knowledge-base QA agent must produce grounded answers strictly based on retrieved corpus context.

Agent **MUST NOT** invent facts, extrapolate unconfirmed conclusions or add information not present in retrieved documents.

When retrieved context similarity score falls below configured threshold, agent shall clearly state “There is no relevant information in current knowledge base” and refuse to speculate answers.

知识库Agent回答必须严格基于检索上下文。禁止编造事实、推断文档不存在的结论。检索相似度低于阈值，系统明确告知知识库无相关信息，拒绝猜测作答。

3. Prompt Injection & Input Sanitization

Basic prompt-injection defence is mandatory for the RAG service:

- Sanitize incoming user prompts to detect instructions trying to override system rules.
- Detect attempts such as “ignore previous instructions”, “forget your rules”, “rewrite your system prompt”.
- Suspicious malicious inputs shall be blocked; event shall be logged for security auditing.

RAG服务必须具备基础提示注入防御：检测“忽略之前指令”“改写系统提示词”这类攻击尝试；恶意输入做拦截并记录安全审计日志。

4. Citation & Traceability Requirement

Every factual answer returned by the QA agent must include source citations: source document name and page reference.

Citation metadata shall be returned together with answer payload for audit purposes.

Do not return citations for answers generated out-of-context or hallucinated content.

所有事实类回答必须附带引用，标明文档名称与页码。引用元数据随接口返回用于审计。幻觉生成的内容不允许伪造引用来源。

5. Data Retention for Chat Sessions

Multi-turn chat session data will be auto-deleted after 30-minute idle timeout.

Persistent storage of full chat history is only enabled for compliance audit purpose and must have PII redaction applied.

Raw user chat data shall not be used for fine-tuning any LLM without formal governance approval.

多轮会话空闲30分钟自动销毁会话数据。完整对话历史仅用于合规审计才持久化，且必须脱敏。未经治理审批，原始对话数据不可用于大模型微调。